

SAT 3812: Cyber Security I

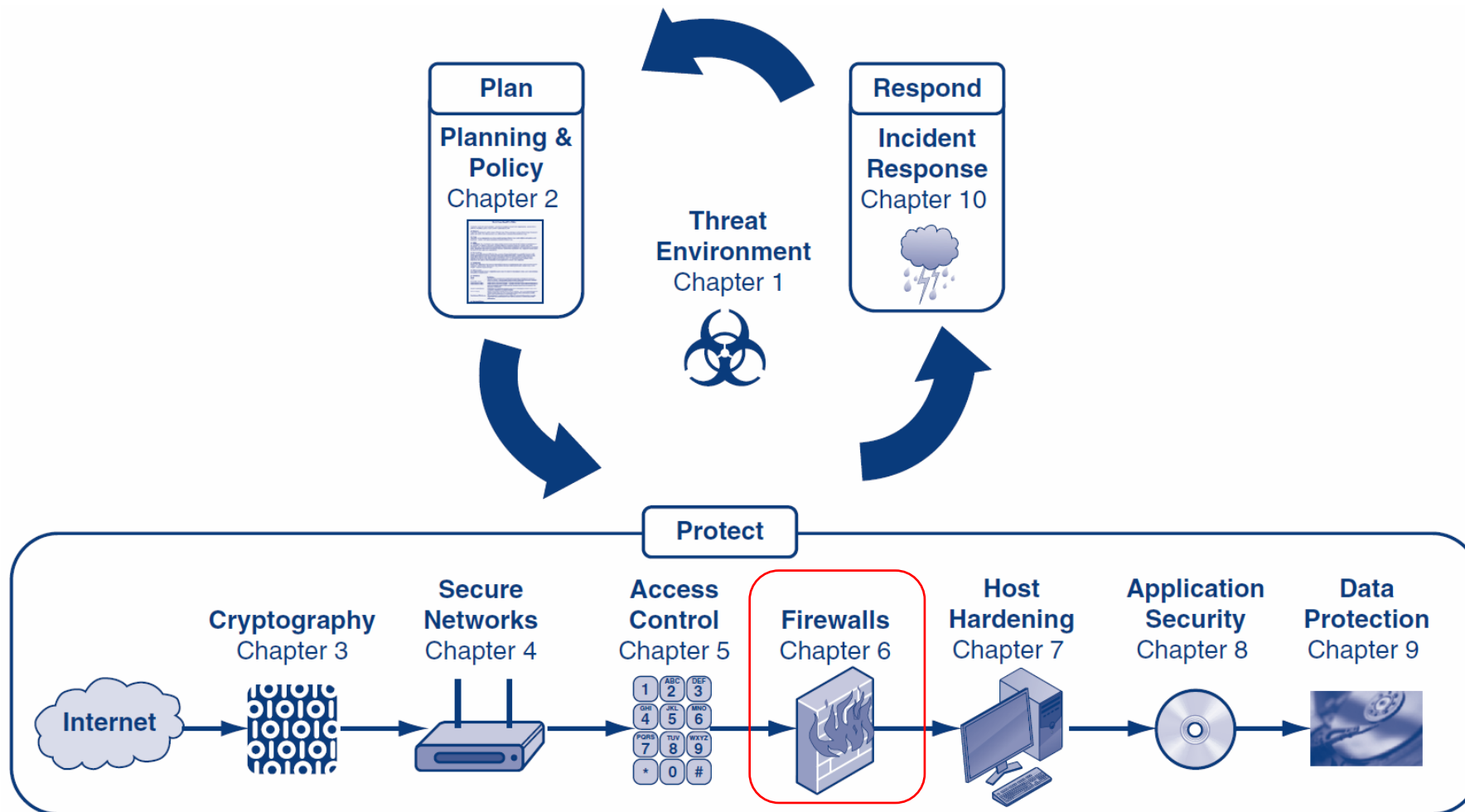
Firewall, IDS, and Incident Response

Instructor: Yunlong Xing



Learning Objectives

- Define firewalls in general (basic operation, architecture, and the problem of overload).
- Describe how static packet filtering, stateful packet inspection (SPI), application proxy firewalls and content filtering in SPI firewalls.
- Explain concepts including NAT and DMZ
- Distinguish between intrusion detection systems (IDSs) and intrusion prevention systems (IPSs).
- Describe firewall management (defining policies, implementing policies, reading log files).
- Describe enterprise network architecture and how multiple security systems work together
- Understand incident response and steps involved



What's Next?

6.1 Introduction

6.2 Static Packet Filtering

6.3 Stateful Packet Inspection (SPI)

6.4 Network Access Translation (NAT)

6.5 Application Proxy Firewalls

6.6 Intrusion Detection Systems (IDSs)

6.7 Antivirus Filtering and Unified Threat Mgt.

6.8 Firewall Architectures

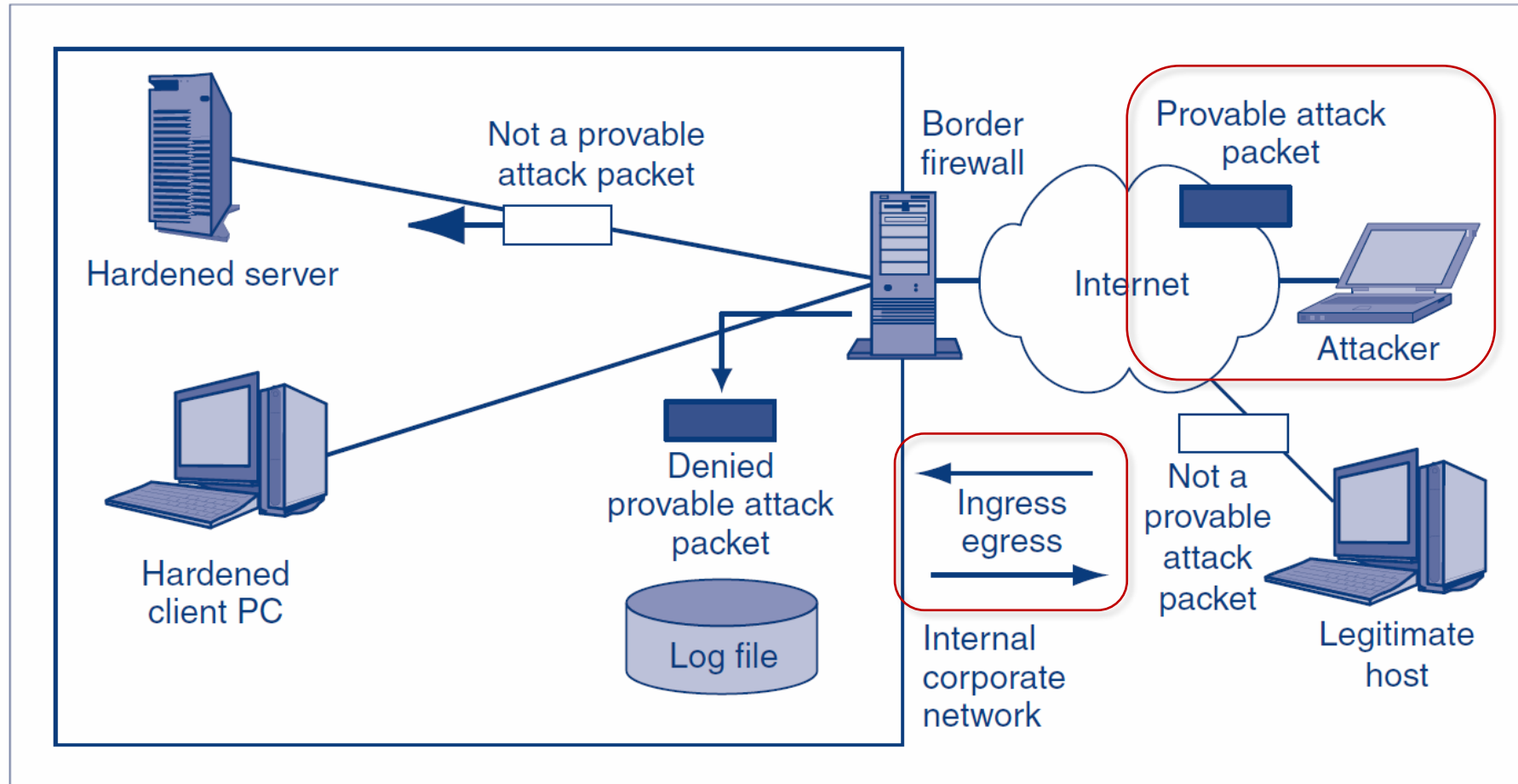
6.9 Firewall Management

6.10 Firewall Filtering Problems

What is Firewall

- A firewall is a network security system that monitors and controls the incoming and outgoing network traffic based on predetermined security rules.
- A firewall typically establishes a barrier between a trusted, secure internal network and untrusted outside network, such as the Internet.

6.1: Basic Firewall Operation



1.

Legitimate hosts send innocent packets.
Attackers send attack packets.

2.

Ingress packets come into a site.
Egress packets go out from a site.

6.1: The Danger of Traffic Overload

- If a firewall cannot filter all of the traffic passing through it, *it drops packets it cannot process (traffic overload)*
- It creates a self-inflicted denial-of-service attack by dropping legitimate traffic
- Firewalls must have the capacity to handle the incoming traffic volume
- Some can handle normal traffic but cannot handle traffic during heavy attacks

What's Next?

6.1 Introduction

6.2 Static Packet Filtering

6.3 Stateful Packet Inspection (SPI)

6.4 Network Access Translation (NAT)

6.5 Application Proxy Firewalls

6.6 Intrusion Detection Systems (IDSs)

6.7 Antivirus Filtering and Unified Threat Mgt.

6.8 Firewall Architectures

6.9 Firewall Management

6.10 Firewall Filtering Problems

6.2: Static Packet Filtering

■ Static Packet Filtering

- This was the earliest and simplest firewall filtering mechanism
- Limits
 - Examines packets one at a time, in isolation
 - Only looks at some internet and transport headers
 - Consequently, unable to stop many types of attacks

Static Packet Filter Firewall

- Basic firewall
- Referred as “screening” firewalls
- Works by examining a packet's:
 - Source/Destination address
 - Source/Destination port
 - IP Protocol Type
 - Interface
- Two default policies:
 - discard - prohibit unless expressly permitted
 - forward - permit unless expressly prohibited

IP Version 4 Packet

IP Version 4 Packet

Bit 0

Bit 31

Version (4 bits)	Header Length (4 bits)	Diff-Serv (8 bits)	Total Length (16 bits)	
Identification (16 bits)			Flags	Fragment Offset (13 bits)
Time to Live (8 bits)	Protocol (8 bits) 1=ICMP, 6=TCP, 17=TCP		Header Checksum (16 bits)	
Source IP Address (32 bits)				
Destination IP Address (32 bits)				
Options (if any)			Padding	
Data Field				

Disadvantages of Packet Filter Firewall

- Does not compare packets
- No authentication
- Susceptible to SYN and Ping flood attacks
- Does not track packets
- Does not look at the packet data just the header
- Offers Moderate security

ACL for Ingress Filtering at a Border Router Cont.

1. If source IP address = 10.*.*.*, DENY
[private IP address range]
2. If source IP address = 172.16.*.* to 172.31.*.*, DENY
[private IP address range]
3. If destination IP address = 60.47.3.9 AND TCP destination port=80 OR 443, PASS
[connection to a public webserver]
4. If TCP SYN=1 AND FIN=1, DENY
[crafted attack packet]

Yellow Tag Question

Can you explain the meaning of the following firewall rules?

1. If TCP SYN=1 AND FIN=1, DENY [*crafted attack packet, why?*]
2. If TCP SYN=1 AND ACK=0, DENY [*attempt to open a connection, why?*]
3. If TCP RST=1, DENY [*do not allow resets, why?*]

TCP Header																															
0								1								2								3							
0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31
Source port																Destination port															
Sequence number																															
Acknowledgment number (if ACK set)																															
Data offset	Reserved 0 0 0			N S	C	E	U	A	P	R	S	F	Window Size																		
					W	C	R	C	S	S	Y	I																			
					R	E	G	K	H	T	N	N																			
Checksum																Urgent pointer (if URG set)															
Options (if <i>data offset</i> > 5. Padded at the end with "0" bytes if necessary.)																															
...																															

“Deny All” Statement

- DENY ALL
 - Last rule
 - Is this what you want?
 - Drops any packets not specifically permitted by earlier rules
 - In the previous ACL, Rules 8-17 are not needed; Deny all would catch them

What's Next?

6.1 Introduction

6.2 Static Packet Filtering

6.3 Stateful Packet Inspection (SPI)

6.4 Network Access Translation (NAT)

6.5 Application Proxy Firewalls

6.6 Intrusion Detection Systems (IDSs)

6.7 Antivirus Filtering and Unified Threat Mgt.

6.8 Firewall Architectures

6.9 Firewall Management

6.10 Firewall Filtering Problems

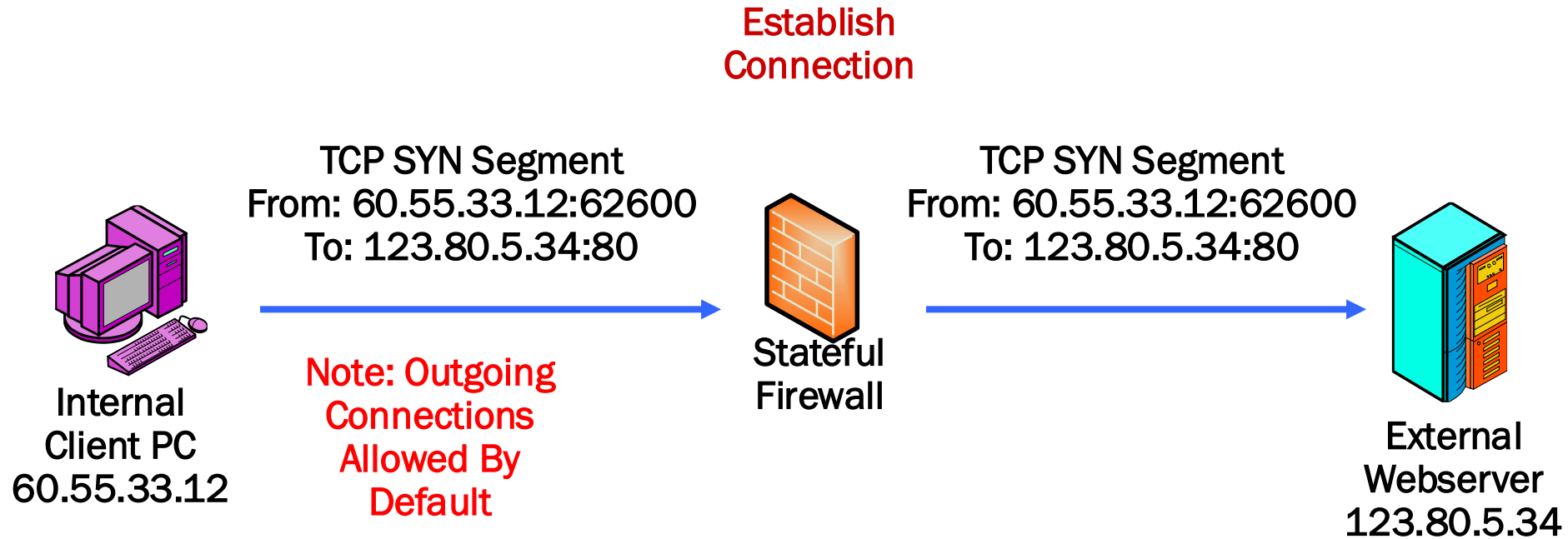
Stateful Inspection Firewall

- **Stateful firewall** tightens rules for TCP traffic using **a directory (or table) of TCP connections**
 - Decision is still made separately for each packet, but **in the context of a connection** (i.e., a session)
 - If new connection, then check against security policy
 - If existing connection, then look it up in the table and update the table, if necessary

Example: Connection State Table

Source Address	Source Port	Destination Address	Destination Port	Connection State
192.168.1.100	1030	210.9.88.29	80	Established
192.168.1.102	1031	216.32.42.123	80	Established
192.168.1.101	1033	173.66.32.122	25	Established
192.168.1.106	1035	177.231.32.12	79	Established
223.43.21.231	1990	192.168.1.6	80	Established
219.22.123.32	2112	192.168.1.6	80	Established
210.99.212.18	3321	192.168.1.6	80	Established
24.102.32.23	1025	192.168.1.6	80	Established
223.212.212	1046	192.168.1.6	80	Established

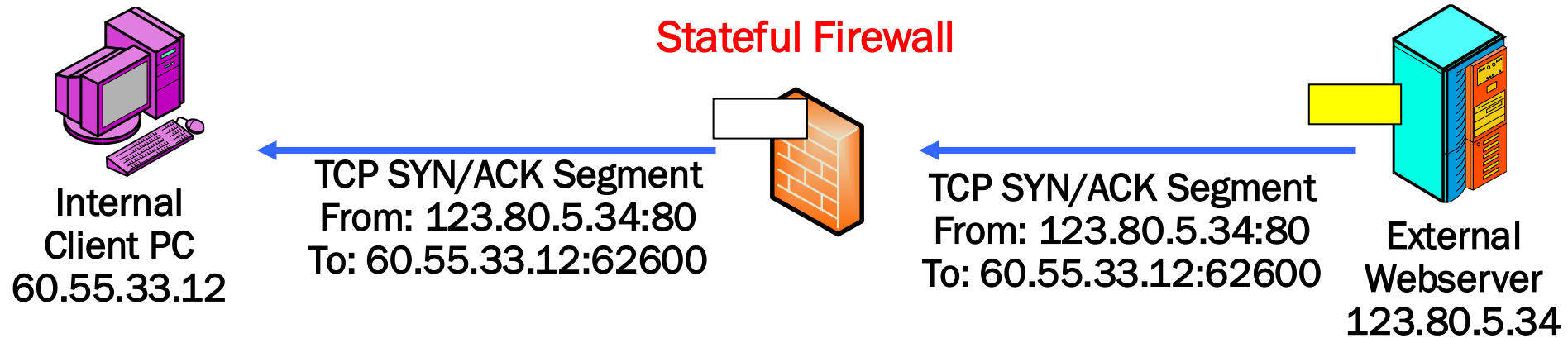
Stateful Inspection Firewall Operation



Connection Table

Type	Internal IP	Internal Port	External IP	External Port	Status
TCP	60.55.33.12	62600	123.80.5.34	80	OK

Stateful Inspection Firewall Operation cont.



**Check Connection
OK;
Pass the Packet**

Connection Table

Type	Internal IP	Internal Port	External IP	External Port	Status
TCP	60.55.33.12	62600	123.80.5.34	80	OK

Stateful Packet Inspection

- Aware of context of packets makes them less susceptible to flood attacks
 - Knows if packet is part of a larger stream
 - Recognizes whether source IP is within the firewall
 - Can look at the contents of the packet

Stateful Inspection Firewall Weakness

- Hard to filter stateless protocols (UDP) and ICMP
- Conservative policy: deny everything that's not allowed
 - Must be careful filtering out service traffic such as ICMP
- Filters can be bypassed with IP tunneling

iptables

- Iptables is a simple firewall system installed by default on many Linux distributions.
 - Should be covered in Linux course
- Examples:

```
iptables -A INPUT -s 10.10.10.10 -j DROP
```

```
iptables -A INPUT -p tcp --dport ssh -s 10.10.10.10 -j DROP
```

```
iptables -A INPUT -p tcp --dport ssh -s 10.10.10.10 -m state  
--state NEW,ESTABLISHED -j ACCEPT
```

What's Next?

6.1 Introduction

6.2 Static Packet Filtering

6.3 Stateful Packet Inspection (SPI)

6.4 Network Access Translation (NAT)

6.5 Application Proxy Firewalls

6.6 Intrusion Detection Systems (IDSs)

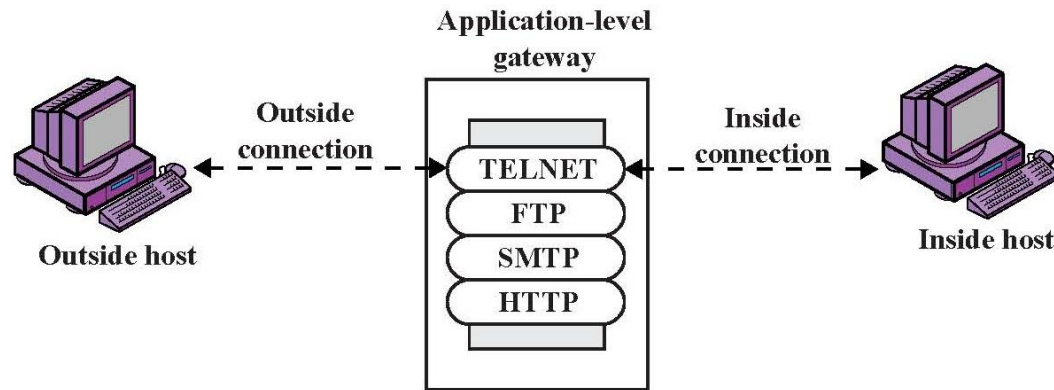
6.7 Antivirus Filtering and Unified Threat Mgt.

6.8 Firewall Architectures

6.9 Firewall Management

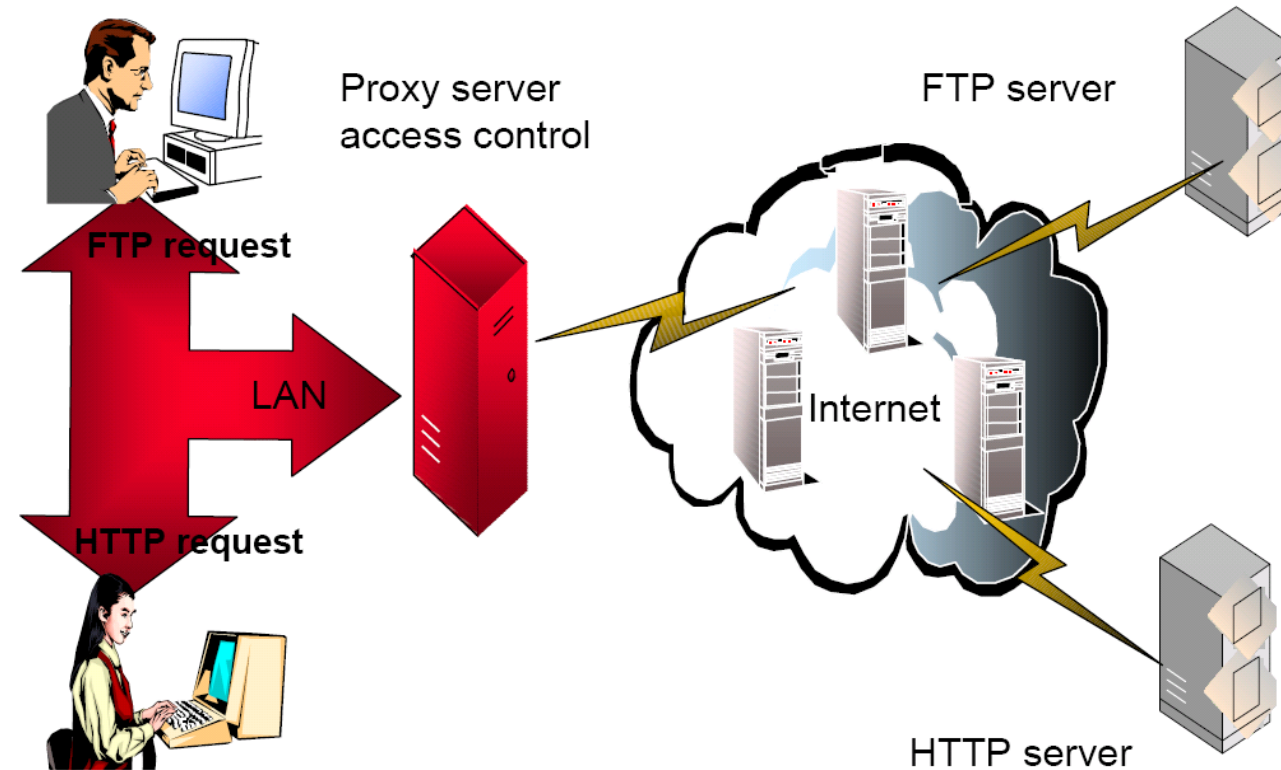
6.10 Firewall Filtering Problems

Application-Level Gateway (or Proxy)



- acts as a relay of application-level traffic
 - Splices and relays application-specific connections
 - Example: **Web browser proxy**
- **user-to-gateway authentication**
 - user contacts gateway with remote host name
 - Log into the server with username and password using Telnet or FTP , etc.
 - gateway contacts application on remote host and relays TCP segments between server and user

Independent Proxy Applications



Application-Level Gateway

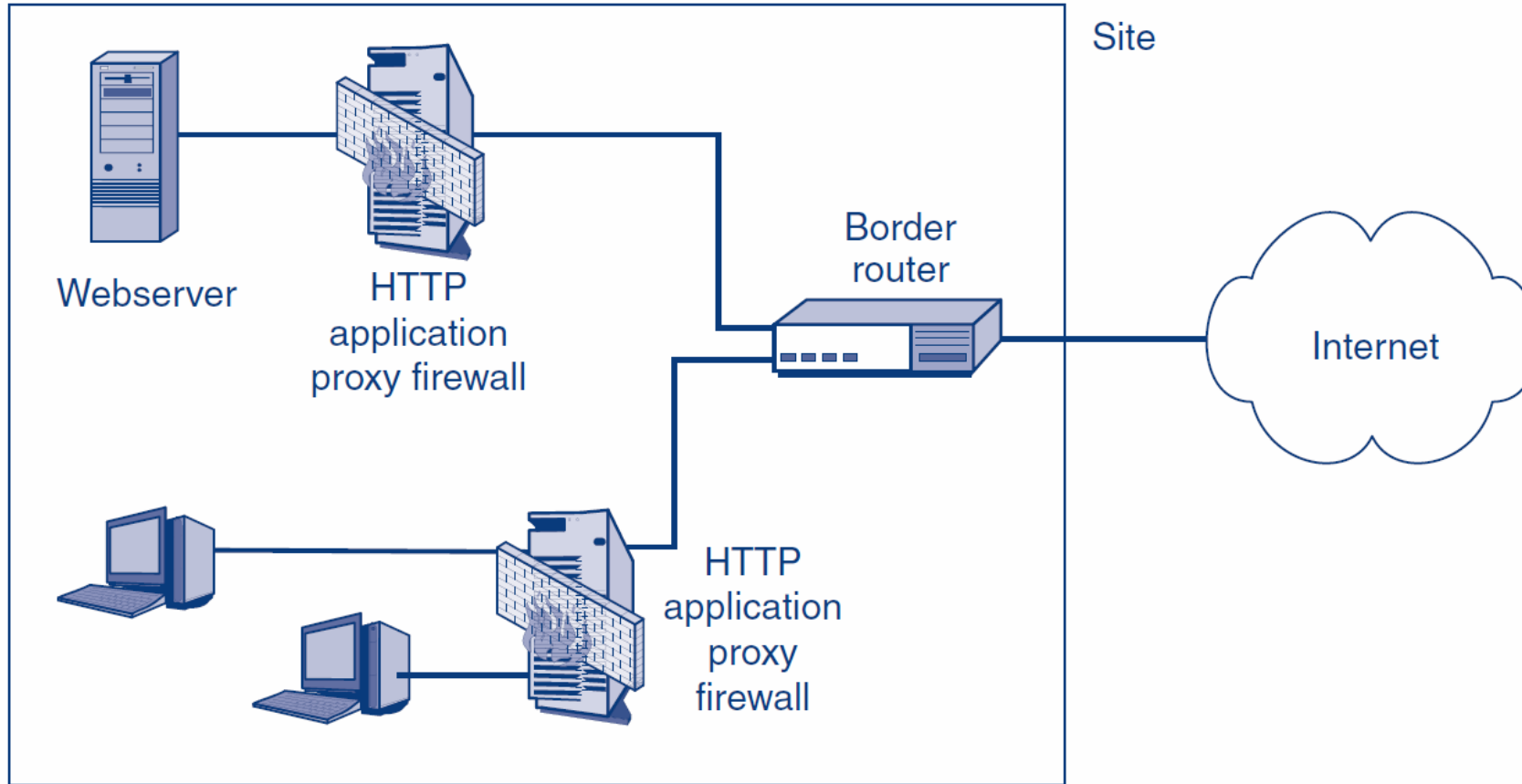
- Must have proxy code for each application
 - may restrict application features supported
- Can be complex and have large overhead
 - but can log and audit all activity

Yellow Tag Questions

- Application-level gateway is general more functional than packet filters using simple rules, why? List at least two reasons.

User authentication; content filtering; complex things

6.5: Roles for Application Proxy Firewalls Today



What's Next?

6.1 Introduction

6.2 Static Packet Filtering

6.3 Stateful Packet Inspection (SPI)

6.4 Network Access Translation (NAT)

6.5 Application Proxy Firewalls

6.6 Intrusion Detection Systems (IDSs)

6.7 Antivirus Filtering and Unified Threat Mgt.

6.8 Firewall Architectures

6.9 Firewall Management

6.10 Firewall Filtering Problems

6.6: Intrusion Detection Systems (IDSs) and Intrusion Prevention Systems (IPSs)

- **Intrusion Detection Systems (IDSs)**
 - Firewalls drop provable attack packets only
 - Intrusion detection systems (IDSs) look for *suspicious* traffic
 - Cannot drop because the packet is merely suspicious
 - Sends an alarm message if the attack appears to be serious

6.6: Intrusion Detection Systems (IDSs) and Intrusion Prevention Systems (IPSs)

■ Intrusion Detection Systems (IDSs)

- Problem: Too many false positives (**false alarms**)
 - Alarms are ignored or the system is discontinued
 - Can reduce false positives by tuning the IDSs
 - Eliminate inapplicable rules, such as a Unix rule in an all-Windows company
 - Reduce the number of rules allowed to generate alarms
 - Most alarms will still be false alarms

6.6: Intrusion Detection Systems (IDSs) and Intrusion Prevention Systems (IPSs)

- **Intrusion Prevention Systems (IPSs)**
 - Attack confidence identification spectrum
 - Somewhat likely
 - Very likely
 - Provable
 - Firm may allow firewall to stop traffic at the high end of the attack confidence spectrum
 - Firm decides which attacks to stop
 - This allows it to manage its risks

6.6: Intrusion Detection Systems (IDSs) and Intrusion Prevention Systems (IPSs)

■ Possible Actions

- Drop packets
 - Risky for suspicious traffic even with high confidence
- Bandwidth limitation (rate limiting) for certain types of traffic
 - Limit to a certain percentage of all traffic
 - Less risky than dropping packets
 - Useful when confidence is lower

Host-Based IPS (HIPS)

- identifies attacks using both:
 - signature techniques
 - malicious application packets (i.e., payload, content)
 - anomaly detection techniques
 - behavior patterns that indicate malware
 - known exploits (buffer overflow, privilege-escalation)
 - modification of system resources (spyware, malicious programs worms, and virus)
 - directory traversal (unauthorized access to files on a web server)
 - access to email contact list
 - Do you need AV if using HIPS?

Host-Based IPS (HIPS)

- NIPS is an inline NIDS
 - that can discard packets or terminate TCP connections
 - also uses signature and anomaly detection
- can identify malicious packets using:
 - pattern matching, stateful matching, protocol anomaly, traffic anomaly, statistical anomaly
- may provide flow data protection
 - monitoring full application flow content
 - drop packets that belong to suspect flows
 - more advanced than a stateful firewall
 - Filters are applied to full content of flow with new packet

NIPS Example: SNORT Inline

- SNORT inline
 - a modified version of snort
 - add three new rules to provide intrusion prevention features
 - Drop
 - Rejects packets and logs result
 - Reject
 - Rejects packet, logs result, and error message is returned
 - Sdrop
 - Rejects packet but does not log the packet
 - can replace (i.e., modify) attacking packets with normal packets so as to terminate attacks
 - suitable for Honeypot applications

Vendors

- Open Source
 - SNORT (IDS/IPS)
 - <http://www.uno-code.com/?q=node/59>Prelude (IDS)
 - HoneyNet (Honey Pot/IDS)
- Commercial
 - TippingPoint
 - Internet Security Systems
 - Juniper
 - RadWare
 - Mirage Networks

NIPS Identifies Malicious Packets

- **Pattern matching**: Scans incoming packets for specific byte sequences (the signature) stored in a database of known attacks.
- **Stateful matching**: Scans for attack signatures in the context of a traffic stream rather than individual packets.
- **Protocol anomaly**: Looks for deviation from standards set forth in RFCs.
- **Traffic anomaly**: Watches for unusual traffic activities, such as a flood of UDP packets or a new service appearing on the network.
- **Statistical anomaly**: Develops baselines of normal traffic activity and throughput, and alerts on deviations from those baselines.

What's Next?

6.1 Introduction

6.2 Static Packet Filtering

6.3 Stateful Packet Inspection (SPI)

6.4 Network Access Translation (NAT)

6.5 Application Proxy Firewalls

6.6 Intrusion Detection Systems (IDSs)

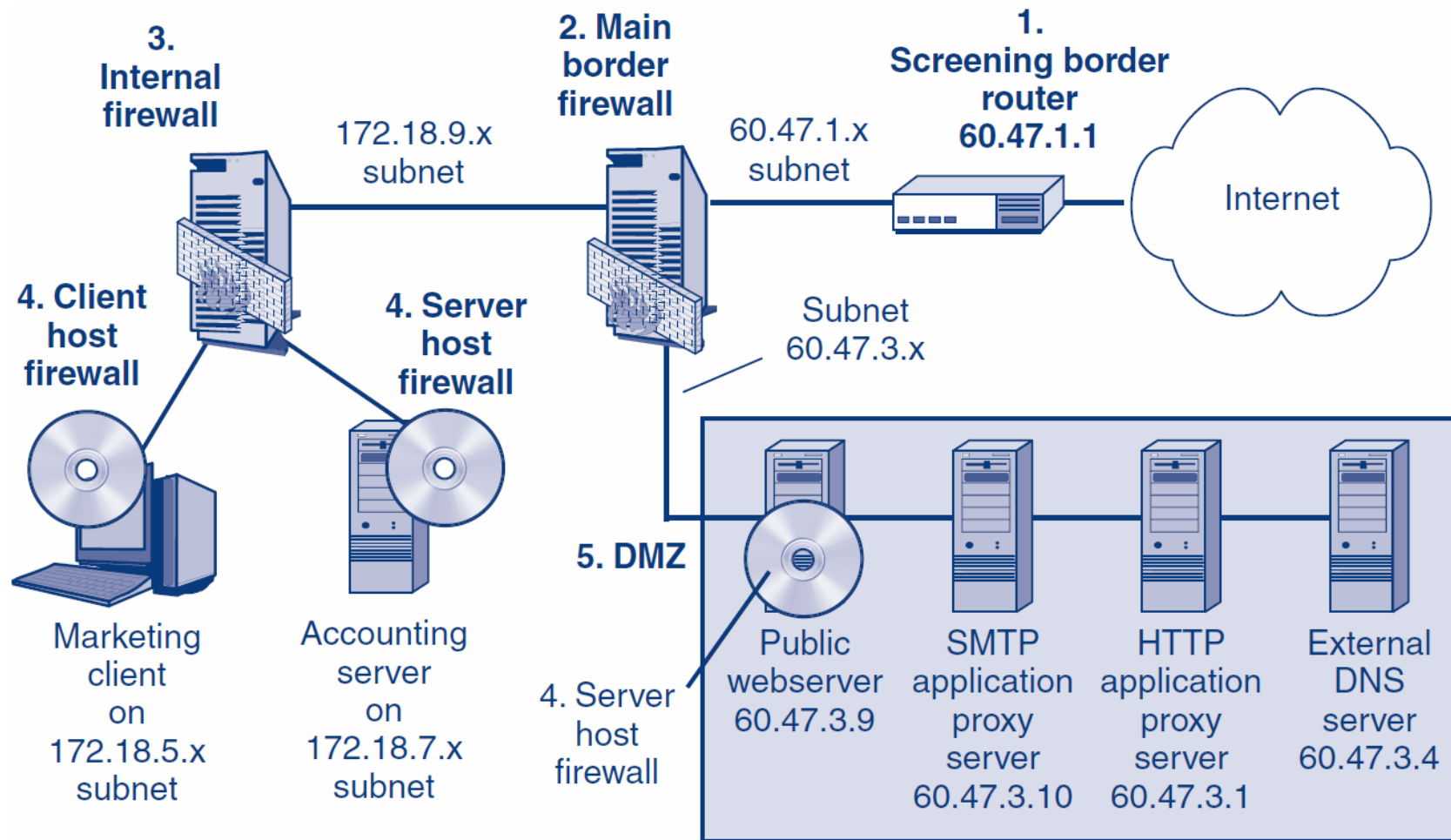
6.7 Antivirus Filtering and Unified Threat Mgt.

6.8 Firewall Architectures

6.9 Firewall Management

6.10 Firewall Filtering Problems

6.8: Firewall Architecture

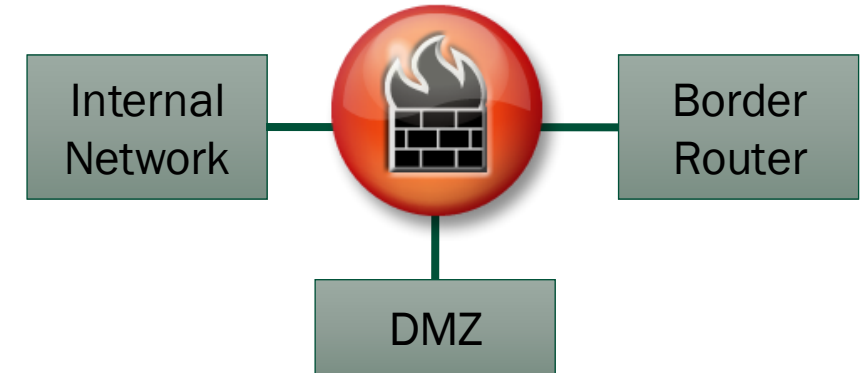


A firm has many firewalls: Screening border routers; Main border firewalls; Internal firewalls; Host firewalls on clients and servers

6.8: The Demilitarized Zone (DMZ)

► DMZs Use Multi-Homed Main Firewalls

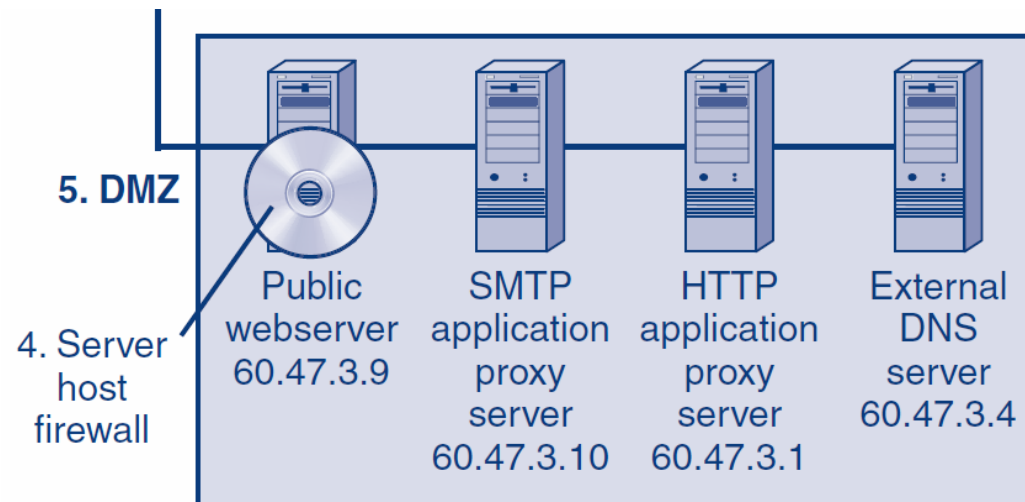
- One subnet to the border router
- One subnet to the DMZ (accessible to the outside world)
- One subnet to the internal network
 - Access from the internal subnet to the Internet is nonexistent or minimal
 - Access from the internal subnet to the DMZ is also strongly controlled
- A Network Enclave is a section of an internal network that is subdivided from the rest of the network.



6.8: The Demilitarized Zone (DMZ)

■ Demilitarized Zone (DMZ)

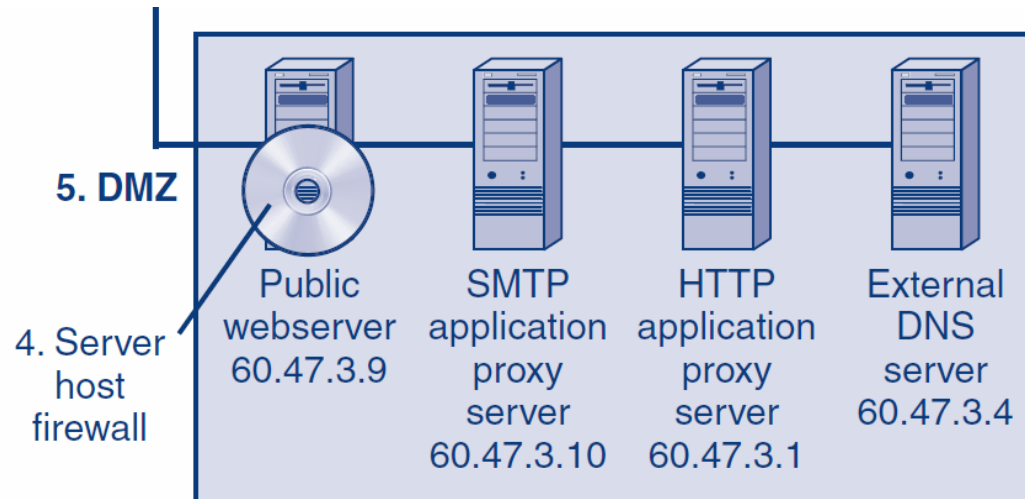
- Subnet for servers and application proxy firewalls accessible via the Internet
- Hosts in the DMZ must be especially hardened because they will be accessible to attackers on the Internet



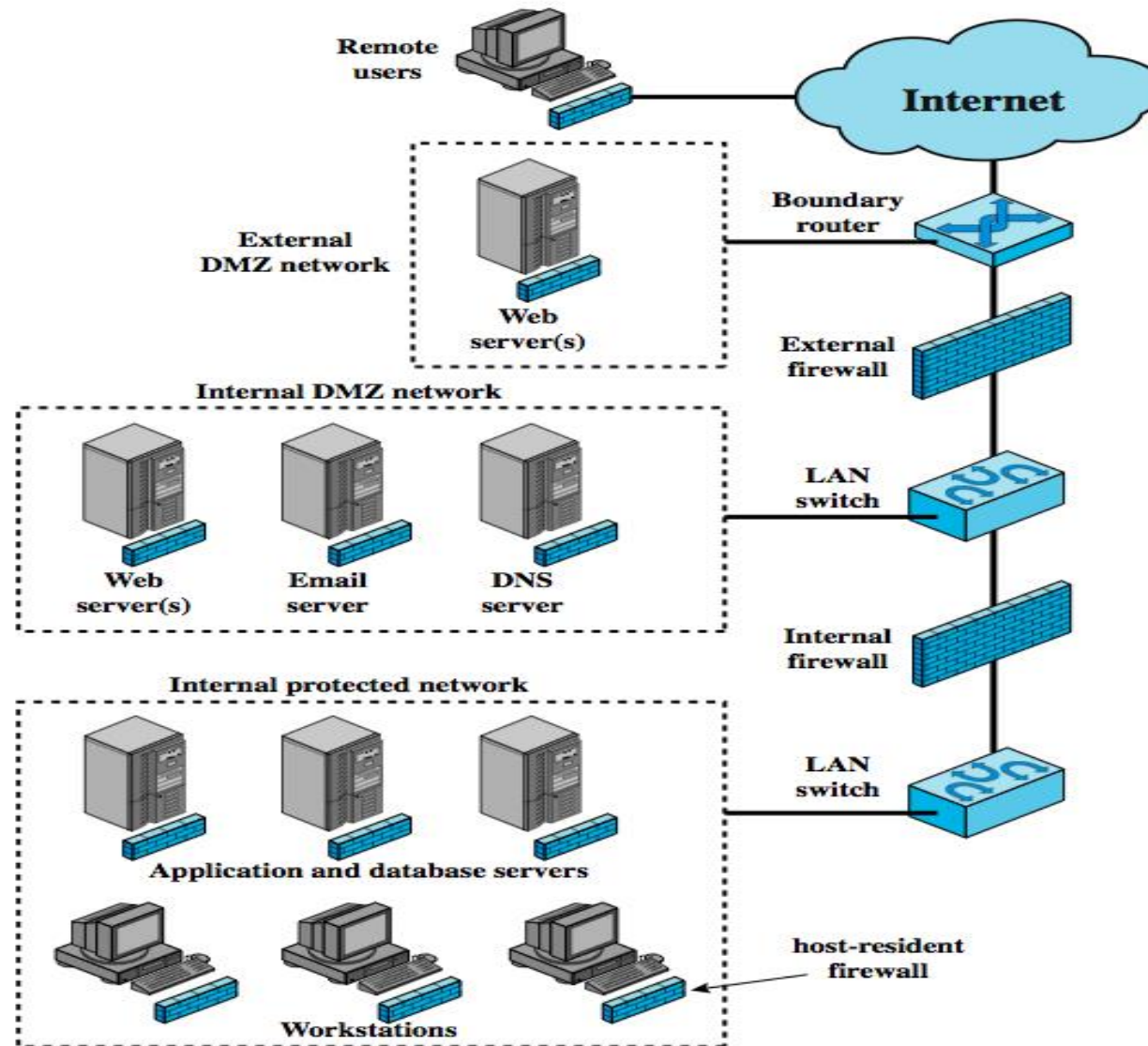
6.8: The Demilitarized Zone (DMZ)

■ Hosts in the DMZ

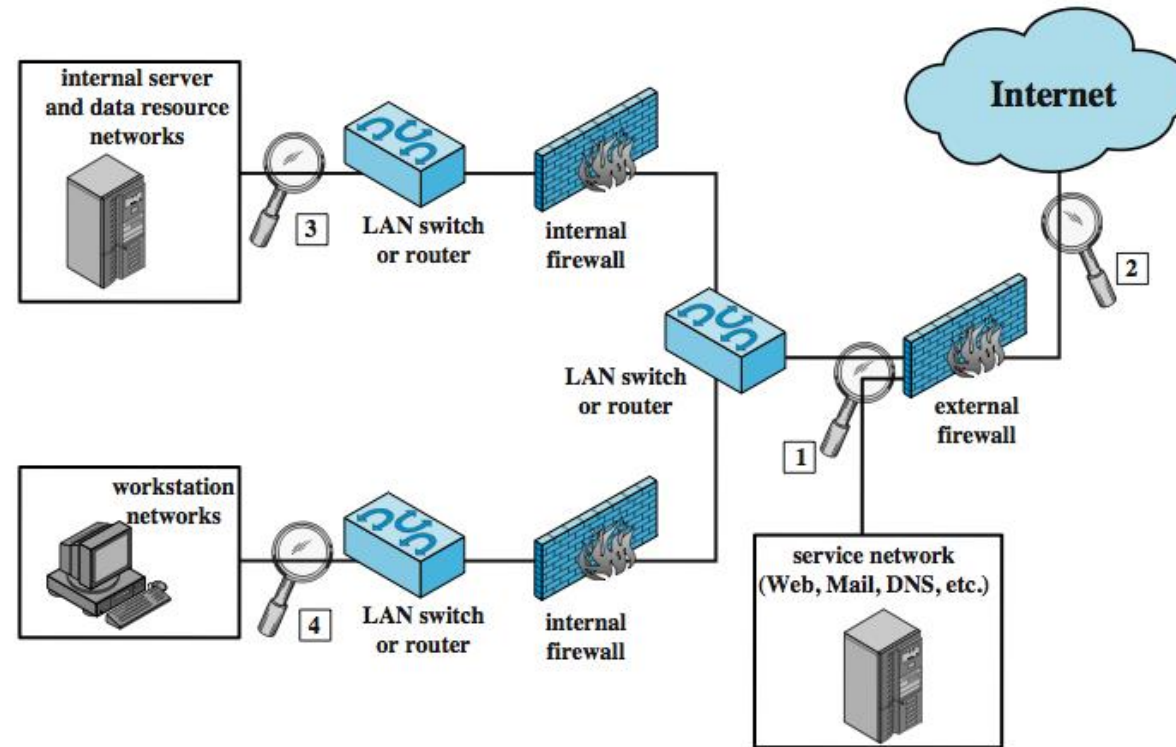
- Public servers (public webserver, FTP servers, etc.)
- Application proxy firewalls to require all Internet traffic to pass through the DMZ
- External DNS server that knows only host names in the DMZ



Firewall Locations



The importance of internal firewall



- A short video on internal firewall
 - <https://www.youtube.com/watch?v=yU3KbVC3nq0>

What's Next?

6.1 Introduction

6.2 Static Packet Filtering

6.3 Stateful Packet Inspection (SPI)

6.4 Network Access Translation (NAT)

6.5 Application Proxy Firewalls

6.6 Intrusion Detection Systems (IDSs)

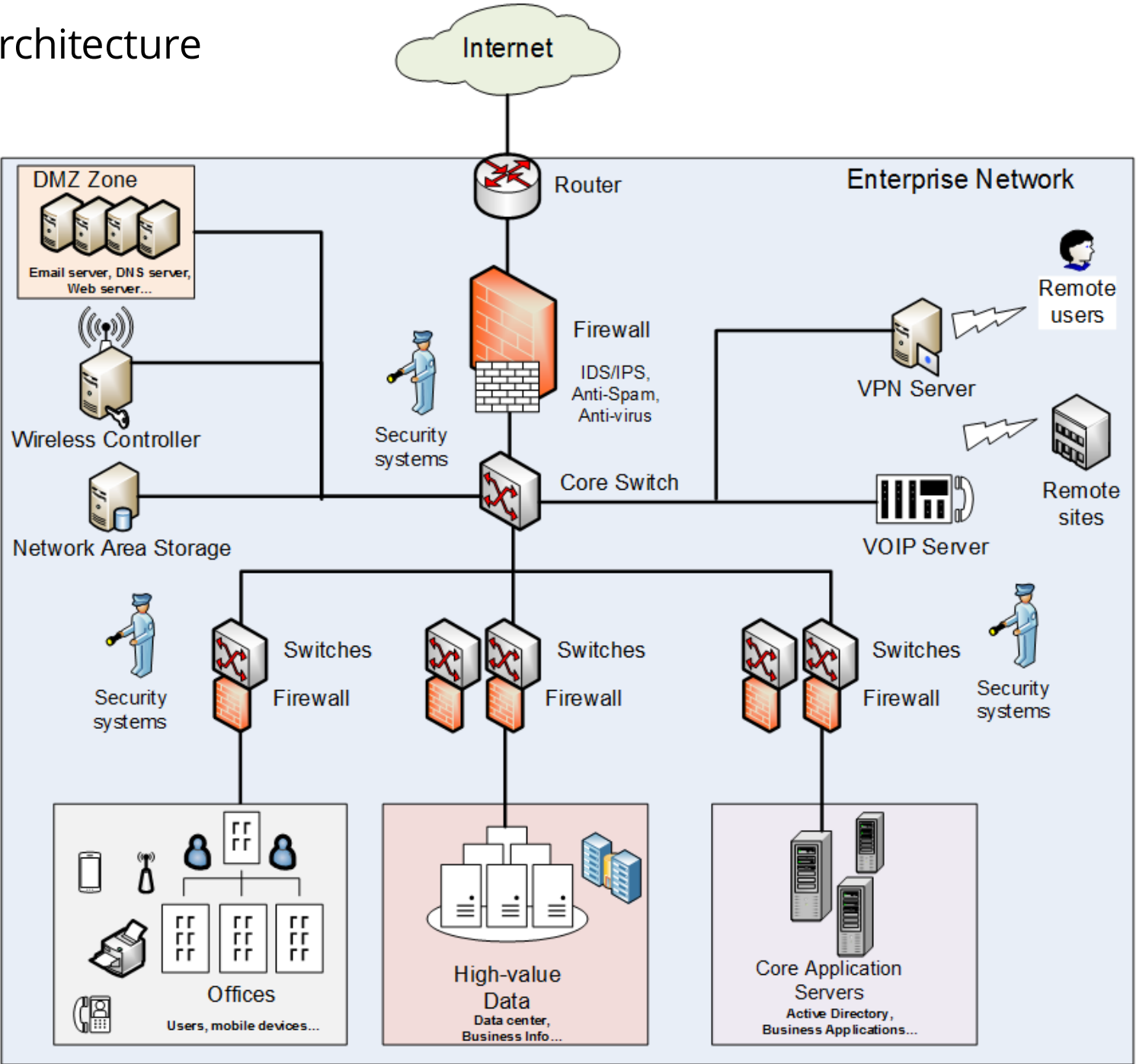
6.7 Antivirus Filtering and Unified Threat Mgt.

6.8 Firewall Architectures

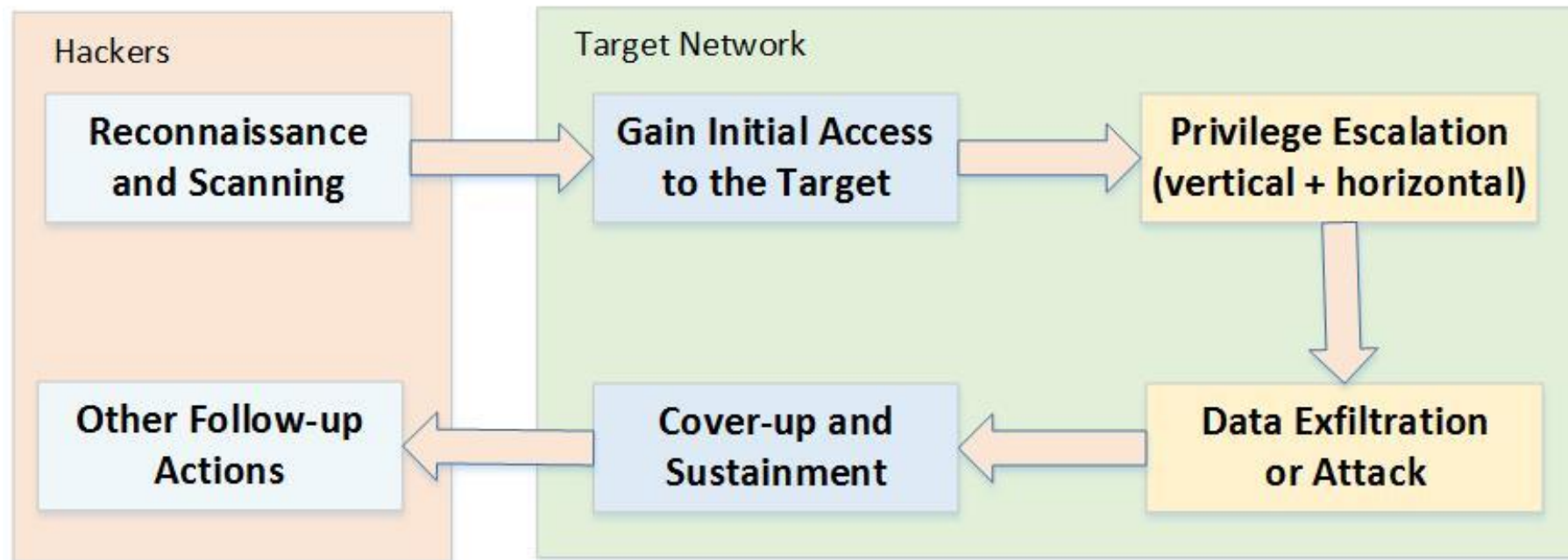
6.9 Firewall Management

6.10 Firewall Filtering Problems

Enterprise Network Architecture

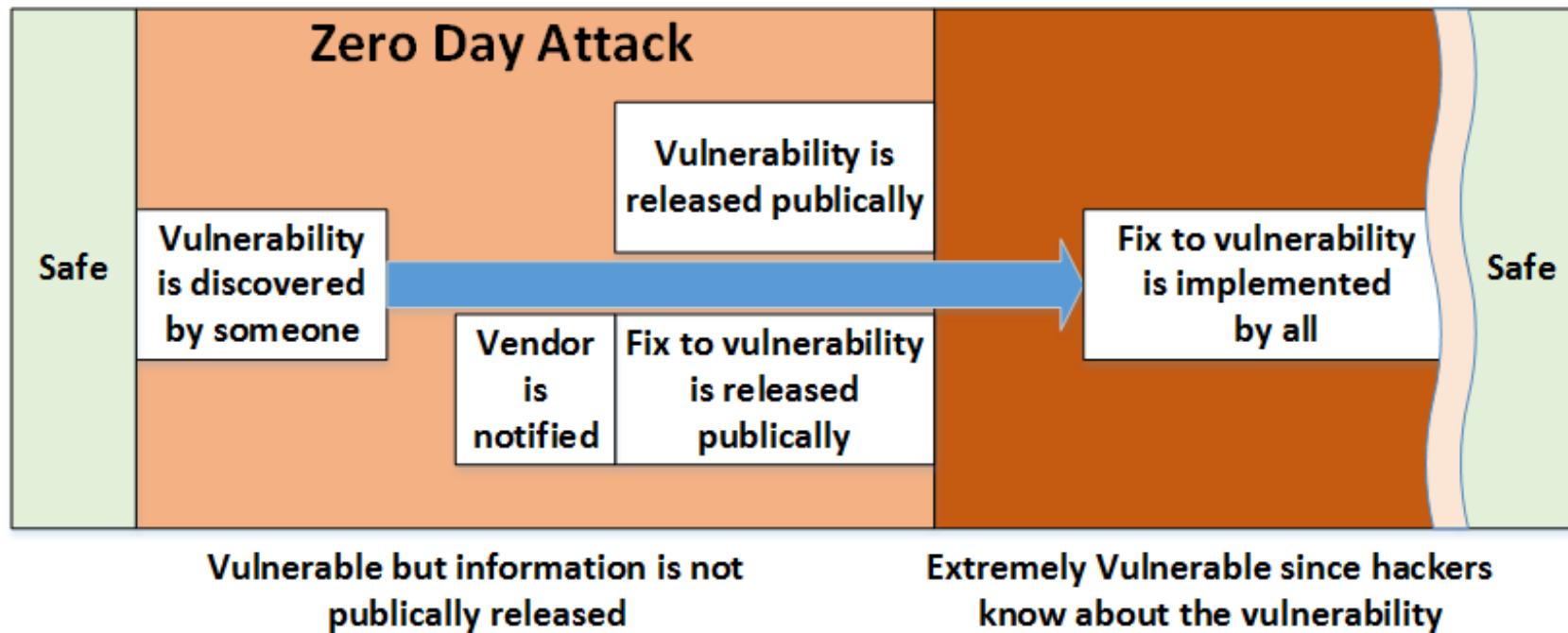


Typical Steps in Cyber Attacks



Zero-Day Vulnerability

Patch your system, or hackers will do it for you.



6.9: Firewall Management

- **Firewalls Are Ineffective Without Planning and Ongoing Management**
- **Defining Firewall Policies**
 - Policies are high-level statements about what to do
 - E.g., HTTP connections from the Internet may only go to servers in the DMZ

6.9: Firewall Management

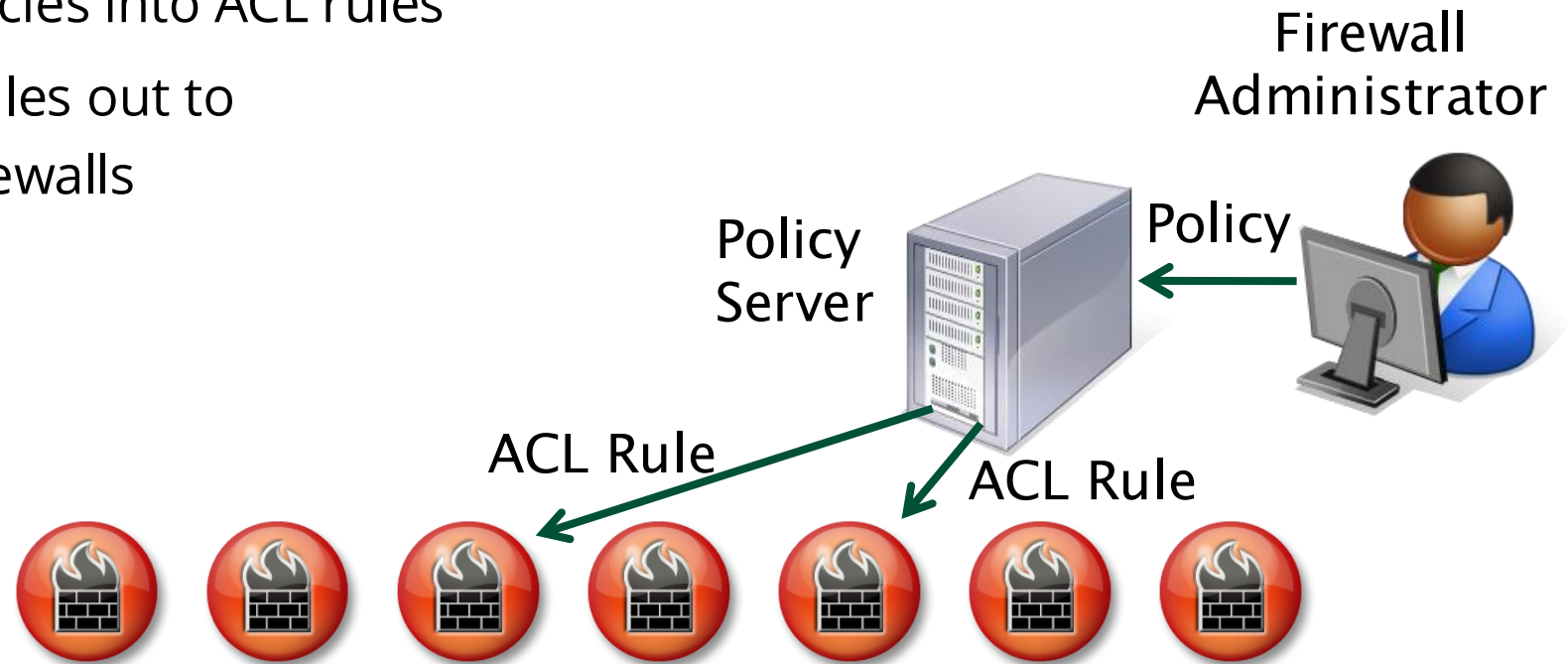
■ Defining Firewall Policies

- Policies are more comprehensible than actual firewall rules
- There may be multiple ways to implement a policy
 - Defining policies instead of specific rules gives implementers freedom to choose the best way to implement a policy

6.9: Firewall Management

■ Implementation: when multiple firewalls...

- Central firewall management systems
 - Creates a policy database
 - Changes policies into ACL rules
 - Sends ACL rules out to individual firewalls



Next Generation Firewall

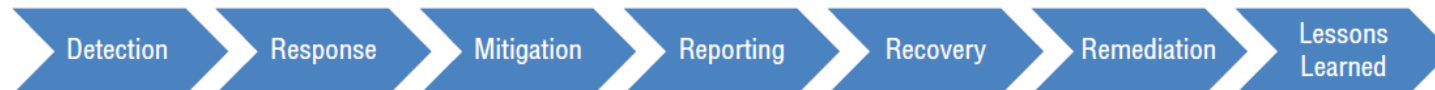
- A Next-Generation Firewall (NGFW) is an integrated network platform that combines a traditional firewall with other network device filtering functionalities such as
 - an application firewall using in-line deep packet inspection (DPI),
 - an intrusion prevention system (IPS)
 - and/or other techniques such as SSL and SSH interception, website filtering, QoS/bandwidth management, antivirus inspection and third-party integration (i.e. Active Directory).

Incident Response

- Incident: Any negative effect on CIA
 - Unplanned interruption to IT
- RFC 2350 “Expectations for Computer Security Incident Response”
 - “Any adverse event which compromises some aspect of computer or network security.”
- NIST SP 800-61
 - Computer Security Incident Handling Guide

Incident Response Steps

- Detection
- Response
- Mitigation
- Reporting
- Recovery
- Remediation
- Lessons Learned



IR Step: Detection

- Detecting actual or potential incidents
- IDSes, AV, audits, automated tools, end users
- First responders
- Incident identification

IR Step: Response

- Based on severity of incident
- Computer incident response team (CIRT)/computer security incident response team (CSIRT)
- Faster response limits damage

IR Step: Mitigation

- Contain the incident
- Limit the effect or scope
- May involve disconnecting from the network
- Actions in this step may be noticed by an attacker

IR Step: Reporting

- Internal and external notification
- May be mandated by regulation
- PII violations are of critical concern in many jurisdictions
- Relevant training is need to properly recognize and report incidents

IR Step: Recovery

- Evidence collection should be completed before recovery efforts
- Recovery is to return the environment to a normal state or condition
- Security should be restored to an equal or greater level than before the incident

IR Step: Remediation

- Analyze the incident to determine the cause
- Implement countermeasures to prevent a recurrence
- Root-cause analysis

IR Step: Lessons Learned

- Determine what can be learned from the incident and the response
- Focus on improving future response
- May highlight need for additional training
- May require adjustment of security infrastructure
- CIRT submits analysis and recommendations report to management